Securing the Help Desk CI/CD Pipeline

Ten milestones. Four reflections. Verified local execution and GitHub checks.

CloudWizardBoricua/sdi4213-week9-devsecops

Issue #1 | Merged security PR #3 | Complete command records

Verified outcome

The original two tests passed before and after hardening in Python 3.13 containers. Streamlit, PostgreSQL, and Adminer ran locally; request creation, listing, status changes, and persistence were exercised. The hardened image returned UID 10001, and both GitHub workflows passed on PR #3 and its merge to main.

Security findings

Docker Scout recorded 97 baseline findings: 5 critical, 41 high, 23 medium, and 28 low across 19 vulnerable packages. These are dated observations of the preserved baseline image. Non-root execution limits privileges; it does not remove vulnerable packages.

How to read the evidence

Pages 2-11 contain Milestones 1-10 in assignment order, with one caption per screenshot. Page 12 continues Milestone 10 with four reflections. The screenshots are embedded at their original aspect ratio and can be enlarged in a PDF viewer.

Capture provenance

Milestones 1, 2, 4, 5, and 7 are browser screenshots of explicitly labeled, read-only views of actual captured command output; they are not native terminal screenshots. Milestones 3, 6, 8, 9, and 10 show the live GitHub interface. Full logs and UTC execution metadata accompany the report in the repository.

Milestone 1 - Establish a Working Baseline

SDI 4213 / WEEK 9 / RECORDED CLI EVIDENCE

Milestone 1 - Baseline application and tests

Read-only transcript viewer. Output comes from actual local command executions.

```
docker run --rm --mount type=bind,source=C:\Users\LPT-TEST-LAB\OneDrive\Desktop\devops\SDI4213_Week9_Student_Starter\tests,target=/app/tests,readonly -e
PYTHONDONTWRITEBYTECODE=1 --entrypoint python helpdesk:week9-before -m pytest -v -p no:cacheprovider tests
```

2026-10-25T20:55:24.336578+00:00 | exit 0 | complete output | original log

```
============================= test session starts ==============================
platform linux -- Python 3.13.17, pytest-8.4.2, pluggy-1.7.0 -- /usr/local/bin/python
rootdir: /app
collecting ... collected 2 items

tests/test_db.py::test_create_and_list_request PASSED                    [ 50%]
tests/test_db.py::test_update_status PASSED                              [100%]

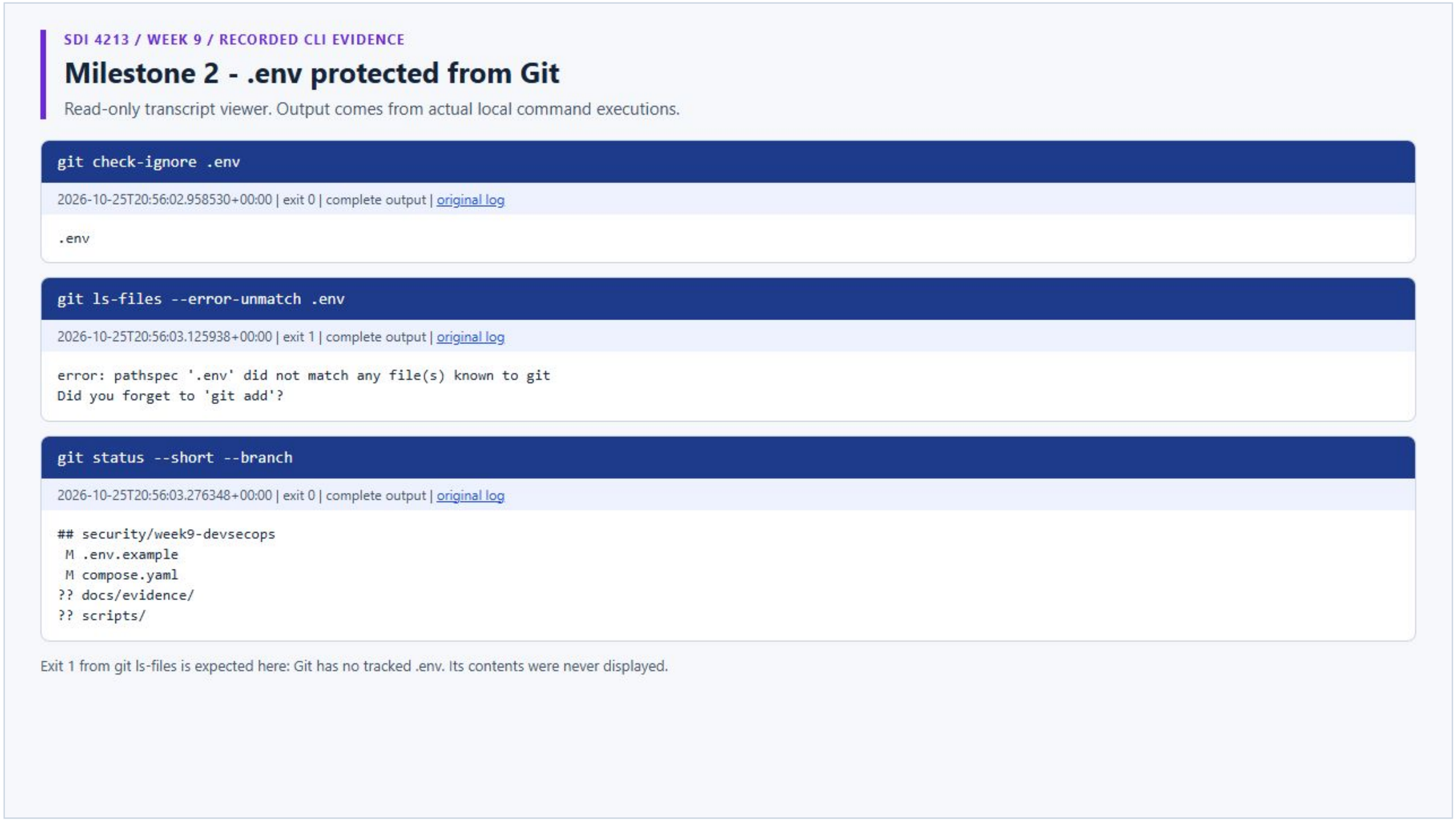
============================== 2 passed in 0.28s ===============================
```

The unchanged baseline image passes both tests; service startup and browser screenshots are preserved separately.

Caption. Both original tests pass in the unchanged Python 3.13 baseline image before Dockerfile hardening.

Open supporting source on GitHub | Captured October 25, 2026

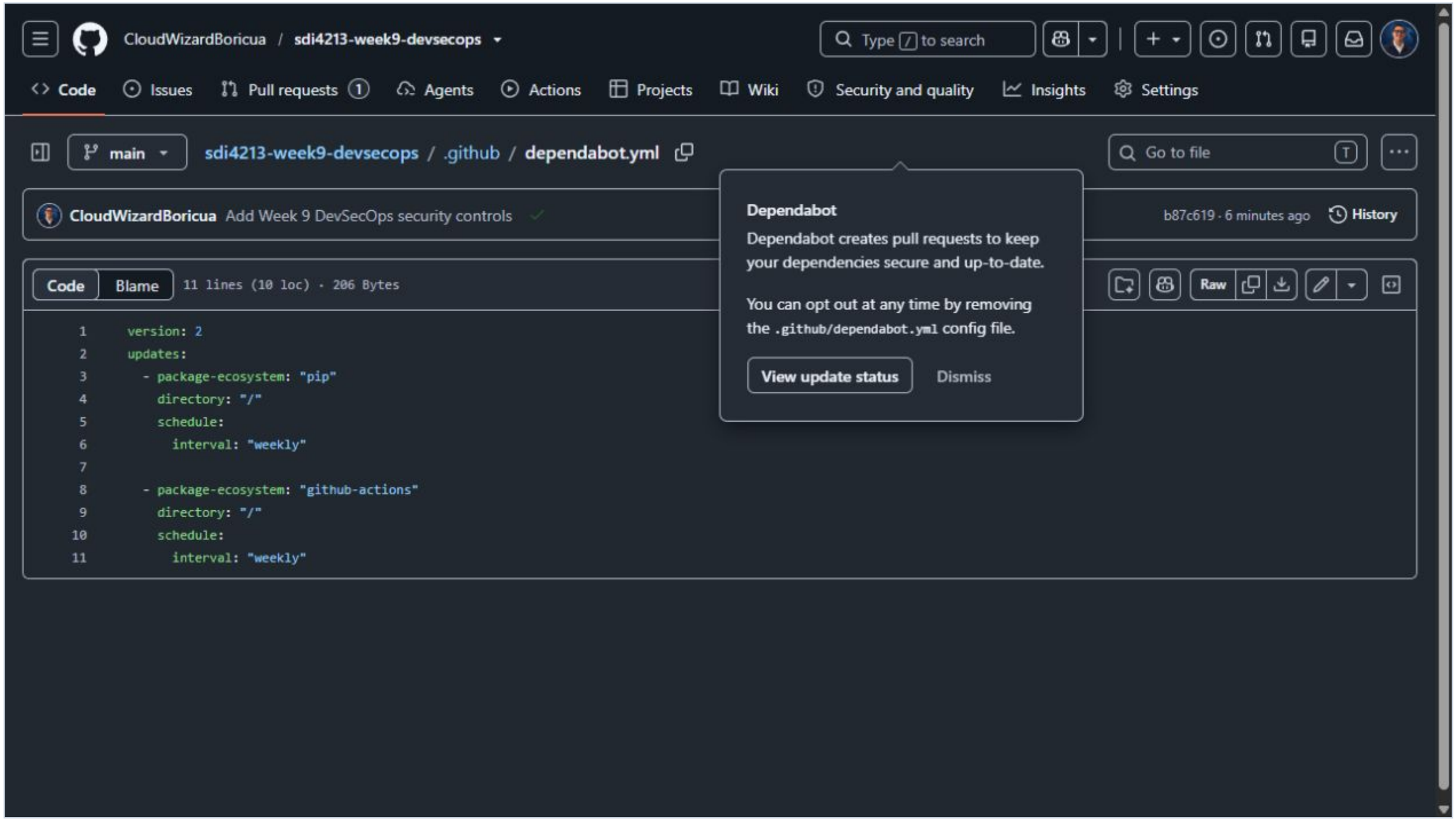
Milestone 2 - Prove .env Is Protected



Caption. Git ignores `.env` and confirms that it is not tracked, without exposing its contents.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 3 - Dependabot Configured



Caption. The configuration published on GitHub schedules weekly updates for pip and GitHub Actions.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 4 - Baseline CVE Scan

SDI 4213 / WEEK 9 / RECORDED CLI EVIDENCE

Milestone 4 - Baseline Docker Scout CVE scan

Read-only transcript viewer. Output comes from actual local command executions.

`docker scout cves helpdesk:week9-before`

2026-10-25T20:55:25.189928+00:00 | exit 0 | excerpt | original log

```
## Overview

                    |       Analyzed Image
--------------------|---------------------------
 Target             |  helpdesk:week9-before
   digest           |  b6f3ce69d928
   platform         | linux/amd64
   vulnerabilities  |    5C    41H    23M    28L
   size             | 200 MB
   packages         | 189
```

This excerpt preserves Scout's severity summary. The full log reports 19 vulnerable packages and 97 findings.

Caption. Scout reports 5 critical, 41 high, 23 medium, and 28 low findings in `helpdesk:week9-before`.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 5 - Recommendations / SBOM Evidence



Caption. Scout identifies the Python 3.13 slim base as up to date while still listing known base-image vulnerabilities.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 6 - Hardened Dockerfile

Code Issues 1 Pull requests 2 Agents Actions Projects Wiki Security and quality Insights Settings

security/week9-d... sdi4213-week9-devsecops / Dockerfile Go to file T

CloudWizardBoricua Add Week 9 DevSecOps security controls b87c619 · 1 minute ago History

Code Blame 22 lines (14 loc) · 532 Bytes Raw

```
1   FROM python:3.13-slim
2
3   WORKDIR /app
4
5   COPY requirements.txt .
6   RUN pip install --no-cache-dir -r requirements.txt
7
8   # A fixed, dedicated identity makes the runtime policy easy to verify.
9   RUN groupadd --gid 10001 appuser \
10      && useradd --uid 10001 --gid appuser --create-home appuser \
11      && chown appuser:appuser /app
12
13  COPY --chown=appuser:appuser app ./app
14
15  ENV PYTHONDONTWRITEBYTECODE=1 \
16      PYTHONUNBUFFERED=1
17
18  EXPOSE 8501
19
20  USER appuser
21
22  CMD ["streamlit", "run", "app/main.py", "--server.address=0.0.0.0", "--server.port=8501"]
```

Caption. The Dockerfile creates `appuser`, assigns ownership, and selects that user before the application command.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 7 - Verify Non-Root Execution

SDI 4213 / WEEK 9 / RECORDED CLI EVIDENCE

Milestone 7 - Non-root container verification

Read-only transcript viewer. Output comes from actual local command executions.

```
docker run --rm --entrypoint id helpdesk:week9-after -u
```

2026-10-25T20:58:32.110780+00:00 | exit 0 | complete output | original log

```
10001
```

```
docker run --rm --entrypoint id helpdesk:week9-before -u
```

2026-10-25T20:55:25.713591+00:00 | exit 0 | complete output | original log

```
0
```

The hardened image returns 10001; the preserved baseline returns 0. Only the hardened image satisfies the policy.

Caption. The hardened image returns UID 10001, compared with UID 0 in the preserved baseline image.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 8 - Security Workflow Added

security/week9-d... sdi4213-week9-devsecops / .github / workflows / security.yml ↑ Top

Code Blame 39 lines (33 loc) · 954 Bytes Raw

```yaml
jobs:
  security-policy:
    runs-on: ubuntu-latest
    timeout-minutes: 15
    steps:
      - name: Check out repository
        uses: actions/checkout@v6

      - name: Reject a tracked .env file
        shell: bash
        run: |
          set -euo pipefail
          if git ls-files --error-unmatch .env >/dev/null 2>&1; then
            echo "::error::.env is tracked; keep local secrets out of Git."
            exit 1
          fi
          echo ".env is not tracked by Git."

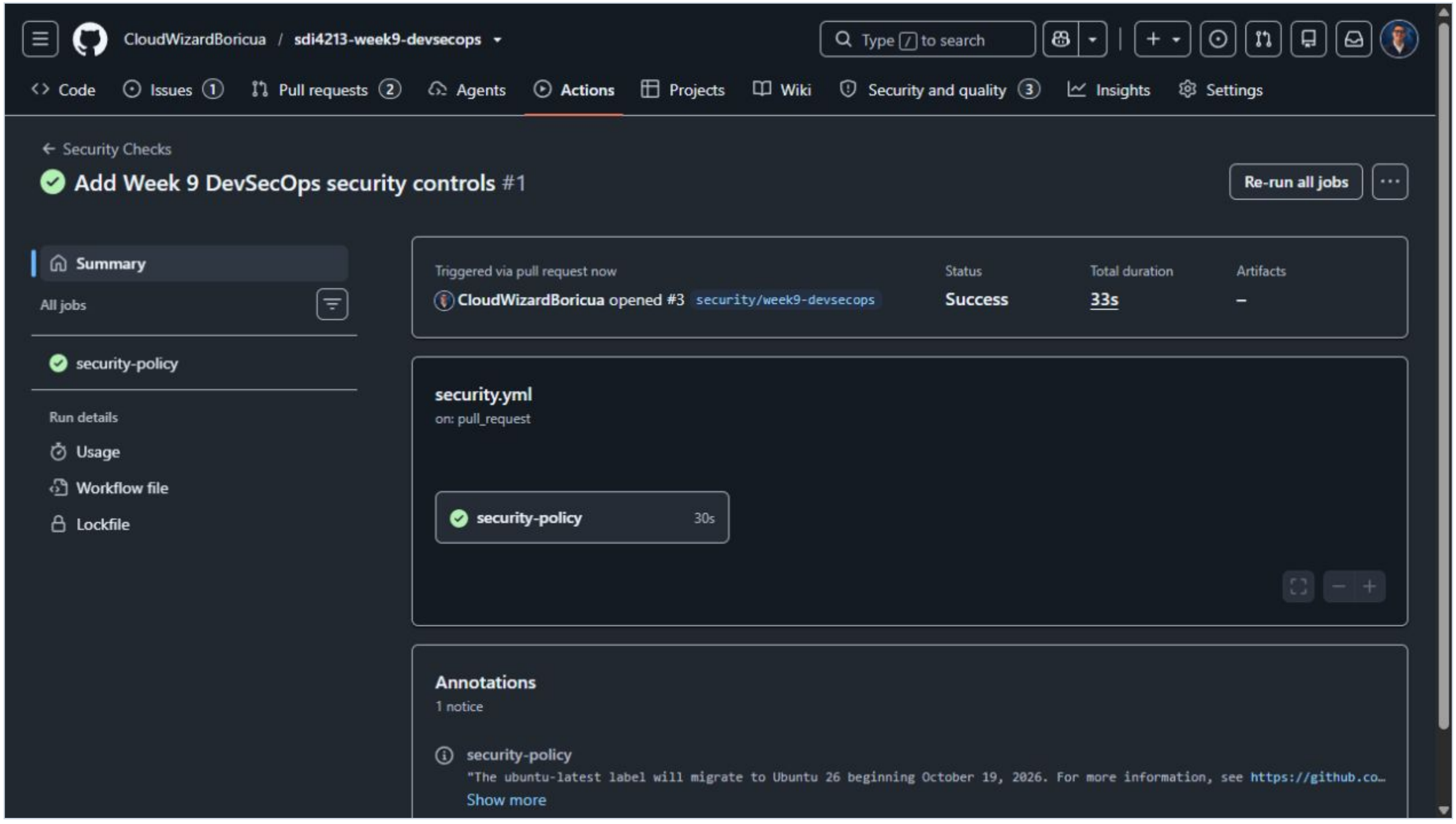
      - name: Build the hardened image
        run: docker build -t helpdesk:security .

      - name: Require a non-root runtime user
        shell: bash
        run: |
          set -euo pipefail
          USER_ID=$(docker run --rm --entrypoint id helpdesk:security -u)
          echo "Container UID: $USER_ID"
          test "$USER_ID" -ne 0
```

Caption. The published workflow rejects tracked `.env` files, builds the image, and requires a non-zero runtime UID.

Open supporting source on GitHub | Captured October 25, 2026

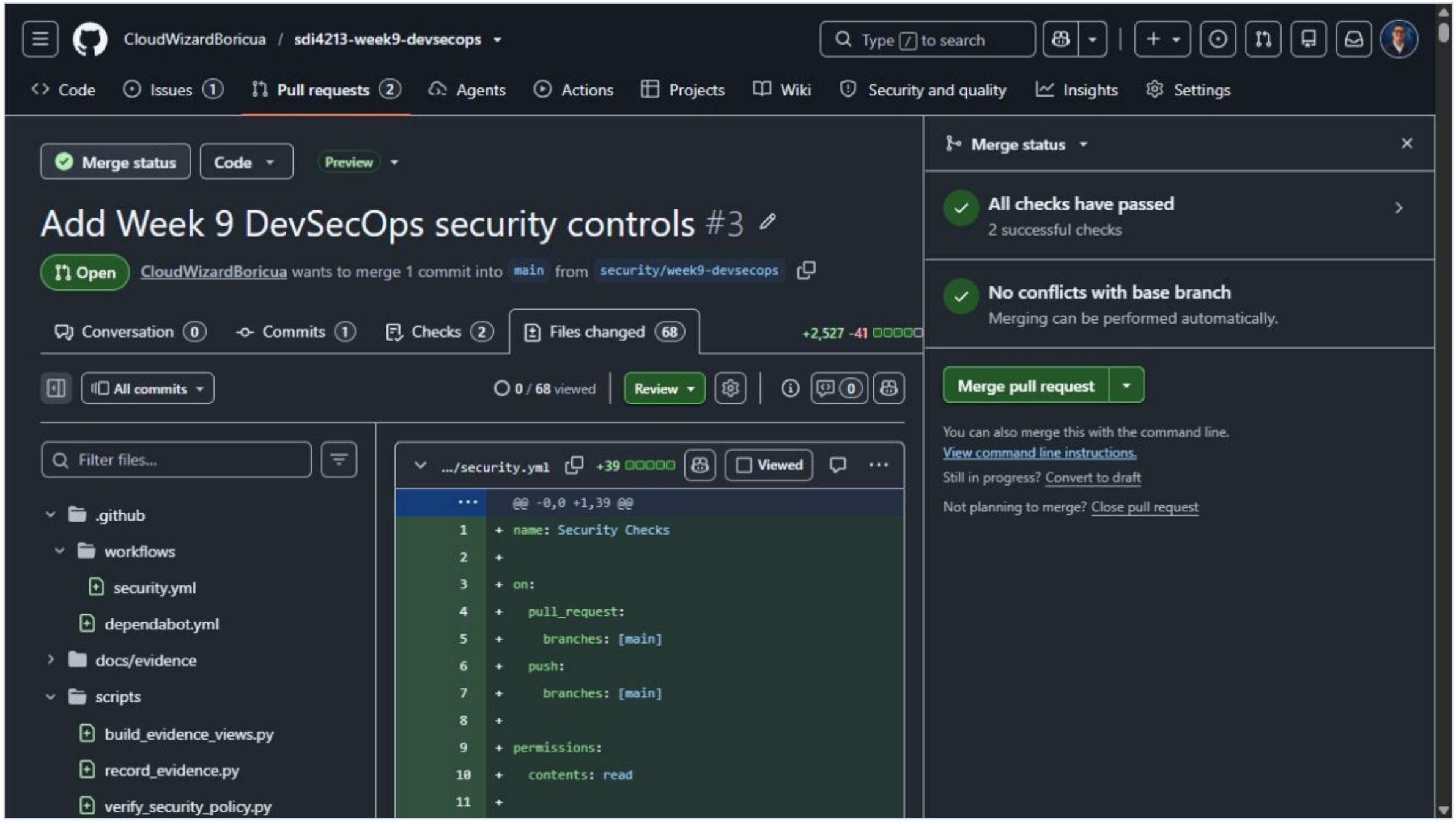
Milestone 9 - Security Checks Passing



Caption. GitHub Actions completes the security-policy job successfully for the security pull request.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 10 - Final Pull Request and Reflection



Caption. The final security pull request records successful checks and the reviewed changes before merge.

Open supporting source on GitHub | Captured October 25, 2026

Milestone 10 - Final Pull Request and Reflection

Reflections beneath Screenshot 10 (continued from the preceding page)

1. What security problem does running a container as non-root reduce?

Running the application as UID 10001 reduces the privileges available if an attacker compromises the application process. Compared with root, the account has fewer opportunities to alter protected operating-system files or perform privileged actions inside the container. This is defense in depth; it does not patch vulnerable packages or guarantee protection from every container escape.

2. What did Docker Scout identify that normal functional tests would not identify?

Scout matched the baseline software inventory to 97 known vulnerability findings, including five critical findings associated with Pillow 11.3.0. The two functional tests passed because they check request storage and status changes, not dependency advisories. These results show why functional correctness and vulnerability analysis answer different questions.

3. Why is .env.example appropriate for Git while .env usually is not?

`.env.example` documents required variable names and uses a conspicuous placeholder instead of a real password. A local `.env` can contain working credentials, so publishing it would expose configuration intended to remain on the developer's machine. Ignore rules protect normal workflows, while CI catches a root `.env` that was forcibly added to Git.

4. How does the security workflow turn a security expectation into an enforceable pipeline policy?

The workflow checks Git's index, builds the image, and evaluates its actual runtime UID on pushes and pull requests targeting `main`. A tracked `.env`, failed build, or root UID makes the job fail instead of relying solely on a manual checklist. Requiring that check through branch protection can additionally prevent merging a failing PR; the workflow itself supplies the automated pass/fail evidence.

Security PR #3 merged October 25, 2026 at 21:16:51 UTC
Merge commit: ca2035c8aeca9a7dae107e403f77e270ed8b4392